

Cybersecurity Checklist for Small Businesses

A Practical Assessment Tool from Lake Tahoe Online (LTOL)

How to Use This Checklist

This checklist is organized into six critical security domains. For each item, mark your current status:

- **In Place** — Fully implemented and maintained
- **Partial** — Started but not complete or consistently maintained
- **Not Done** — Not yet implemented

Your goal isn't perfection on day one. Focus on addressing the highest-risk gaps first, then work through the remaining items systematically.

Section 1: Device & Endpoint Security

Your computers, phones, and tablets are the front line of your security posture. Every device that connects to your network or accesses your data is a potential entry point for attackers.

#	Security Measure	Status
1.1	All computers run a supported operating system (Windows 11, macOS 14+, or current Linux LTS)	
1.2	Automatic OS updates are enabled on all devices	
1.3	Antivirus/anti-malware software is installed and actively scanning	
1.4	Full-disk encryption is enabled (BitLocker on Windows, FileVault on Mac)	
1.5	Screen lock activates after 5 minutes of inactivity	
1.6	USB ports are restricted or monitored	
1.7	Mobile devices have remote wipe capability enabled	
1.8	Personal devices accessing company data have a minimum security policy (MDM)	
1.9	Decommissioned devices are securely wiped before disposal	
1.10	A hardware inventory is maintained and reviewed quarterly	

Why This Matters

A single unpatched laptop can give an attacker access to your entire network. The 2024 Verizon Data Breach Investigations Report found that 68% of breaches involved a human element — often through a compromised endpoint.

Quick Wins

- Enable automatic updates on all devices today
- Turn on disk encryption (it's free and built into every modern OS)
- Set up remote wipe on all mobile devices

Section 2: Email & Phishing Protection

Email remains the number one attack vector for small businesses. Over 90% of cyberattacks begin with a phishing email.

#	Security Measure	Status
2.1	Email filtering/spam protection is active	
2.2	SPF, DKIM, and DMARC records are configured for your domain	
2.3	External email warnings are displayed (banner on emails from outside the organization)	
2.4	Attachment scanning is enabled	
2.5	Link scanning/URL rewriting is active	
2.6	Employees have received phishing awareness training in the last 12 months	
2.7	A process exists for reporting suspicious emails	
2.8	Executive/VIP accounts have enhanced protection	
2.9	Auto-forwarding rules are restricted or monitored	
2.10	Email retention policies are defined and enforced	

Why This Matters

Business Email Compromise (BEC) cost organizations \$2.9 billion in 2023 according to the FBI's Internet Crime Report. These attacks don't require sophisticated malware — just a convincing email that tricks someone into wiring money or sharing credentials.

Quick Wins

- Set up SPF, DKIM, and DMARC records (your IT provider can do this in under an hour)
 - Enable external email banners so employees know when an email comes from outside
 - Run a phishing simulation to baseline your team's awareness
-

Section 3: Password & Access Management

Weak or reused passwords are involved in over 80% of data breaches. Proper access management ensures that even if one account is compromised, the damage is contained.

#	Security Measure	Status
3.1	A password policy requires minimum 12 characters with complexity	
3.2	Multi-factor authentication (MFA) is enabled on all business accounts	
3.3	A password manager is provided to all employees	
3.4	Shared accounts are eliminated or minimized	
3.5	Access is granted on a least-privilege basis (employees only access what they need)	
3.6	Terminated employee accounts are disabled within 24 hours	
3.7	Admin/privileged accounts are separate from daily-use accounts	
3.8	Access reviews are conducted at least quarterly	
3.9	Service accounts have strong, unique passwords that are rotated	
3.10	Single Sign-On (SSO) is used where possible to centralize access control	

Why This Matters

Once an attacker has valid credentials, they look like a legitimate user. MFA alone blocks 99.9% of automated credential attacks according to Microsoft's security research.

Quick Wins

- Enable MFA on email, banking, and CRM immediately (this is the single highest-impact action)
- Deploy a password manager to eliminate password reuse
- Audit who has admin access and remove unnecessary privileges

Section 4: Backup & Recovery

Ransomware attacks increased 95% in 2024. Your ability to recover from an attack — or even a simple hardware failure — depends entirely on the quality of your backups.

#	Security Measure	Status
4.1	Critical business data is backed up at least daily	
4.2	Backups follow the 3-2-1 rule (3 copies, 2 media types, 1 offsite)	
4.3	At least one backup is air-gapped or immutable (cannot be modified by ransomware)	
4.4	Backup restoration is tested at least quarterly	
4.5	Recovery Time Objective (RTO) is defined for critical systems	
4.6	Recovery Point Objective (RPO) is defined (how much data loss is acceptable)	
4.7	Email and cloud data (Microsoft 365, Google Workspace) is backed up separately	
4.8	A documented disaster recovery plan exists	
4.9	Key personnel know how to initiate recovery procedures	
4.10	Backup encryption is enabled for data at rest and in transit	

Why This Matters

Many businesses assume their cloud provider backs up their data. They don't. Microsoft 365's retention policies are not a backup — they're designed for compliance, not disaster recovery. If ransomware encrypts your files in OneDrive, those encrypted versions sync to the cloud.

Quick Wins

- Verify your backups actually work by restoring a test file today
- Ensure Microsoft 365 / Google Workspace data has a third-party backup

- Document your recovery procedures so they don't live in one person's head

Section 5: Network Security

Your network is the highway connecting all your systems. Without proper controls, an attacker who gains access to one device can move laterally to everything else.

#	Security Measure	Status
5.1	Business-grade firewall is in place (not consumer-grade router)	
5.2	Wi-Fi uses WPA3 encryption with a strong passphrase	
5.3	Guest Wi-Fi is on a separate network segment from business systems	
5.4	Remote access uses VPN or Zero Trust Network Access (ZTNA)	
5.5	Unused network ports and services are disabled	
5.6	Network traffic is monitored for anomalies	
5.7	IoT devices (cameras, printers, smart devices) are on a separate VLAN	
5.8	DNS filtering blocks known malicious domains	
5.9	Firmware on network equipment is current	
5.10	Network diagram is documented and current	

Why This Matters

Flat networks (where every device can talk to every other device) allow attackers to move freely once they compromise a single endpoint. Network segmentation contains breaches and limits damage.

Quick Wins

- Separate guest Wi-Fi from your business network immediately
- Enable DNS filtering (services like Cisco Umbrella or Cloudflare Gateway are inexpensive)

- Update firmware on your router/firewall

Section 6: Employee Awareness & Training

Technology alone cannot protect your business. Your team is both your greatest vulnerability and your strongest defense — depending on their training.

#	Security Measure	Status
6.1	All employees complete security awareness training at onboarding	
6.2	Refresher training is conducted at least annually	
6.3	Phishing simulations are run at least quarterly	
6.4	A clear process exists for reporting security incidents	
6.5	Employees know not to share credentials or bypass security controls	
6.6	Social engineering awareness is included in training	
6.7	Physical security practices are covered (clean desk, locked screens, visitor policies)	
6.8	Acceptable use policies are documented and acknowledged	
6.9	Security champions are identified in each department	
6.10	Security metrics (phishing click rates, incident reports) are tracked over time	

Why This Matters

The best firewall in the world can't stop an employee from clicking a convincing phishing link. Regular training reduces phishing susceptibility by up to 75% according to KnowBe4's research data.

Quick Wins

- Send a company-wide reminder about phishing red flags

- Establish a simple reporting process (even a dedicated email address like security@yourcompany.com)
 - Run your first phishing simulation to establish a baseline
-

Scoring Your Results

Count your responses across all 60 items:

Score Range	Rating	Recommended Action
50–60 In Place	Excellent	Annual review and continuous improvement
35–49 In Place	Good	Address remaining gaps within 90 days
20–34 In Place	Needs Work	Prioritize critical gaps immediately; consider professional assessment
Under 20 In Place	At Risk	Seek professional help now; your business is significantly exposed

Next Steps

1. **Take our free Cybersecurity Risk Assessment** at ltol.com to get a personalized risk score and recommendations.
 2. **Book a Strategy Session** to discuss your specific security gaps and build a remediation plan.
 3. **Start with the quick wins** — MFA, backups verification, and email protection deliver the most value fastest.
-

Lake Tahoe Online (LTOL) — Managed IT & Digital Marketing for Northern Nevada and Beyond

Phone: (530) 582-2080 | **Email:** support@ltol.com | **Web:** ltol.com